

History and Evolution of Cybersecurity, Standards, ISC2, and CISSP

To understand CISSP and modern cybersecurity, we first need to understand how technology and security evolved over time.

The story of cybersecurity did not begin directly with hackers, malware, or the Internet. It developed gradually alongside electrical technology, computers, shared systems, networking, and eventually the Internet and cloud computing.

Early Standardization and the IEC

During the late nineteenth and early twentieth centuries, electrical technology was developing rapidly. Different countries and manufacturers were developing electrical equipment, terminology, measurement methods, and technical practices.

This created a need for international agreement and standardization.

In 1906, the **International Electrotechnical Commission (IEC)** was established.

IEC was not a company that manufactured or directly protected electrical equipment. It was created to develop and coordinate international standards related to electrical and electrotechnical technologies.

Its work helped establish common standards and terminology for areas such as:

- Electrical equipment
- Electrical safety
- Electronics
- Power systems
- Industrial systems
- Communication technologies

This represents an important general principle that later became very important in computing and cybersecurity:

When technology becomes widely used, common terminology, rules, and standards become necessary.

Alan Turing and the Foundations of Computing

During the 1930s, scientists and mathematicians were exploring the theoretical foundations of computation.

In 1936, British mathematician and logician **Alan Turing** introduced a theoretical model of computation that later became known as the **Turing Machine**.

The Turing Machine was not the first physical computer. It was a mathematical model explaining how a machine could follow a sequence of instructions to perform computation.

This work became one of the major theoretical foundations of computer science.

During the 1940s, practical electronic computers began to emerge through the work of many researchers, engineers, governments, universities, and organizations.

At this stage, computers were:

- Very large
- Extremely expensive
- Rare
- Usually isolated
- Used mainly by governments, militaries, universities, and large organizations

Because these computers were not connected like modern systems, cybersecurity as we understand it today did not yet exist.

Security mainly meant:

Protect the building → Protect the machine → Protect documents → Control personnel → Protect military and government secrets

Therefore, early computer security was mainly based on **physical security and information secrecy**.

Alan Turing and the Idea of Machine Intelligence

Alan Turing later contributed another important idea.

In 1950, he published the paper **Computing Machinery and Intelligence**, beginning with the famous question:

“Can machines think?”

Turing proposed the **Imitation Game**, which later became popularly known as the **Turing Test**.

The simplified concept is that if a human communicates through text with a human and a machine and cannot reliably identify which one is the machine, the machine demonstrates convincing human-like conversational behavior.

This idea later became influential in discussions about **Artificial Intelligence (AI)**.

It is important to separate Turing's two famous contributions:

1936 — Turing Machine → Theory of computation

1950 — Imitation Game/Turing Test → Machine intelligence

These ideas influenced different areas of modern computing.

The Beginning of Computer Security

As computers became more useful during the 1950s, governments, military organizations, universities, and businesses began storing valuable information in computer systems.

The security question started changing from only:

“How do we physically protect this machine?”

to:

“Who should be allowed to use the machine and access its information?”

Security still relied heavily on:

- Locked rooms

- Guards
- Personnel authorization
- Security clearance
- Classified information procedures

However, the idea of controlling access to computer systems was becoming increasingly important.

1960s: Shared Systems Changed Security

During the 1960s, **time-sharing systems** became important.

Previously, a computer might be used for one task or by a limited number of authorized operators. Time-sharing allowed multiple users to interact with the same computer system.

This created new security questions:

- How do we identify each user?
- How do we authenticate the user?
- How do we protect one user's files from another user?
- How do we control permissions?
- How do we isolate processes and information?

This period contributed to the development of concepts such as:

- User accounts
- Passwords
- Permissions
- Access control
- System isolation

Therefore, the 1960s are an important period in the development of recognizable **technical computer security**.

ISO and International Standardization

Meanwhile, technology and international trade were growing across many industries.

Different countries and organizations often had different technical standards, terminology, measurements, manufacturing requirements, and practices.

To support international standardization, the **International Organization for Standardization (ISO)** was established in **1947**.

ISO is an independent, non-governmental international organization that develops international standards.

ISO was not created specifically for computer networking. Its work covers many industries, including:

- Technology
- Information security
- Manufacturing
- Quality management
- Medical devices
- Environmental management
- Food safety

The basic purpose of standardization is:

Different experts and countries agree on common requirements, terminology, and practices so that systems, products, and organizations can work more consistently and reliably.

Later, ISO became important in computing and networking as those technologies developed.

1969 and 1970s: Networking Changed Security

A major change occurred when computers started communicating with other computers.

ARPANET began operating in **1969** and became an important early packet-switched network and predecessor in the history of the modern Internet.

Before networking, security largely focused on protecting an individual computer system.

Networking changed the security problem:

Isolated Computer Security

became:

Computer + User + Data + Communication + Network Security

Now an attacker or unauthorized user did not necessarily need to be physically present at the computer.

Data could travel between systems, and connected computers created new risks.

During the 1970s, security research increasingly addressed:

- Access control
- Secure operating systems
- Network communication
- Authentication
- Data protection
- Security policies

The **1970 Ware Report**, *Security Controls for Computer Systems*, became an important historical contribution to computer security thinking.

Development of the OSI Model

As computer networking grew, different vendors developed different networking technologies and architectures.

There was a need for common ways to describe and understand network communication.

ISO contributed to the development and standardization of the **OSI Reference Model**.

The OSI model organizes network communication conceptually into seven layers:

1. Physical
2. Data Link
3. Network
4. Transport
5. Session
6. Presentation
7. Application

The OSI model was not the reason ISO was originally created. ISO existed before modern computer networking.

However, the OSI model is an example of how an international standards organization later contributed to the development of common networking concepts.

1980s: Personal Computers, Networks, and Malware

During the 1980s, personal computers became more common and computer networks continued to expand.

As more systems became connected, new security threats appeared.

Malicious software became a growing concern, and organizations needed better ways to:

- Detect attacks

- Protect systems
- Investigate incidents
- Share security information
- Respond to computer emergencies

The **1988 Morris Worm** demonstrated how quickly malicious or uncontrolled software could spread across connected systems.

This incident contributed to the establishment of organized computer emergency response capabilities, including the creation of the **CERT Coordination Center (CERT/CC)**.

Cybersecurity was becoming a professional field, but another problem existed.

Different security organizations, vendors, governments, and professionals used different:

- Terminology
- Security practices
- Knowledge areas
- Professional expectations
- Training approaches

Security knowledge was distributed across many areas, including:

- Physical security
- Computer security
- Network security
- Cryptography
- Access control
- Risk management
- Governance

There was no single widely shared professional body of knowledge covering the broader information-security profession.

1989: Formation of ISC2

To address the need for a common professional approach, several organizations collaborated to establish the **International Information System Security Certification Consortium**, now known as **ISC2**, in **1989**.

ISC2 is a nonprofit professional organization focused on cybersecurity education and certification.

Its goal was to develop a vendor-neutral professional certification approach and establish a shared **Common Body of Knowledge (CBK)**.

Why is it called the CBK?

CBK means:

Common Body of Knowledge

It represents a shared collection of:

- Security concepts
- Terminology
- Principles
- Professional practices
- Security knowledge areas

The idea is:

Cybersecurity is a very large field → Important professional knowledge is organized into a common body → Professionals can develop a shared understanding of security concepts and responsibilities.

The CBK is not a security tool, a single book, or a cybersecurity framework.

It represents the organized body of professional cybersecurity knowledge.

1990s: Internet Security and the Need for Security Professionals

During the 1990s, the Internet and World Wide Web expanded rapidly.

Organizations began using technology for:

- Websites
- Email
- Business communication
- E-commerce
- Online services
- Financial transactions

The security profession expanded beyond protecting computers and networks.

Organizations needed professionals who understood:

- Technical security
- Network security
- Risk management
- Governance
- Access control
- Security architecture
- Security testing
- Incident response
- Business continuity
- Secure software development

This created demand for professionals who could understand security from a complete organizational perspective.

1994: Launch of CISSP

In **1994**, ISC2 launched the **CISSP certification**.

CISSP stands for:

Certified Information Systems Security Professional

CISSP was designed to validate broad professional cybersecurity knowledge.

It is **vendor-neutral**, meaning that its main purpose is not to teach only one company's technology.

For example:

Cisco certification → Focus may be on Cisco technologies

AWS certification → Focus may be on AWS cloud technologies

Microsoft certification → Focus may be on Microsoft technologies

CISSP focuses on broader security principles and professional knowledge that can apply across different technologies and environments.

CISSP covers areas from technical security to organizational security, including:

- Risk management
- Governance
- Asset protection
- Security architecture
- Network security
- Identity and access management
- Security testing
- Security operations
- Incident management
- Software security

Therefore, CISSP provides a broad view of cybersecurity rather than focusing only on hands-on hacking or one specific security tool.

CISSP and ISO/IEC 17024

CISSP later achieved important international recognition through accreditation associated with **ISO/IEC 17024**.

ISO/IEC 17024 is an international standard related to organizations that certify individuals.

The term **ISO/IEC** means that ISO and IEC cooperate in the relevant area of standardization.

This helped demonstrate that the CISSP certification program was operated according to recognized requirements for personnel certification.

Is CISSP Entry-Level?

No.

CISSP is **not an entry-level cybersecurity certification**.

It is intended for experienced cybersecurity professionals.

For full CISSP certification, ISC2 generally requires:

5 years of cumulative paid work experience in at least 2 of the 8 CISSP domains.

A relevant four-year degree or approved credential may provide a one-year experience waiver, reducing the requirement to four years.

A person may pass the CISSP examination before having all the required experience, but passing the examination alone does not automatically mean that the person has become a fully certified CISSP professional.

The simple relationship is:

Exam Knowledge + Required Experience + ISC2 Certification Requirements = Full CISSP Certification

For beginners, CISSP knowledge can still be useful as a map of the complete cybersecurity field, but practical technical skills and entry-level experience should be developed first.

The Eight CISSP Security Domains

The current CISSP knowledge structure is organized around eight domains:

1. Security and Risk Management
2. Asset Security
3. Security Architecture and Engineering
4. Communication and Network Security
5. Identity and Access Management (IAM)
6. Security Assessment and Testing
7. Security Operations
8. Software Development Security

Together, these domains provide a broad view of organizational cybersecurity.

A simple understanding is:

**Risk → Assets → Architecture → Networks → Identity → Testing →
Operations → Software Security**

Why Is CISSP Still Relevant When Technology Changes?

Technology has changed significantly since CISSP was launched in 1994.

In the past, an organization might have protected:

A physical office + Local network + Local servers

Today, an organization may need to protect:

**Cloud infrastructure + SaaS applications + Remote workers + Mobile devices
+ APIs + Containers + AI systems + Global networks**

The technology has changed, but many fundamental security questions remain the same:

- What are we protecting?
- What is the risk?
- Who is the user?
- How is the user authenticated?
- What is the user authorized to access?
- How is sensitive information protected?
- How is activity monitored?
- How are attacks detected?
- How does the organization respond to incidents?
- How does the organization recover?

For example:

Old environment:

Company file server

Modern environment:

Cloud storage service

The implementation is different, but the security process may still include:

Classification → Access Control → Encryption → Monitoring → Backup → Recovery

This is why older fundamental security principles remain important.

Technology changes, but security objectives such as these remain relevant:

- Confidentiality
- Integrity
- Availability
- Least privilege
- Defense in depth
- Separation of duties
- Authentication
- Authorization
- Network segmentation
- Risk management
- Incident response
- Business continuity

The methods and technologies used to implement these principles continue to evolve.

CISSP Domains

Domain 1: Security and Risk Management

Definition

Security and Risk Management is the foundation of cybersecurity. It focuses on identifying risks, protecting organizational assets, creating security policies, complying with laws and regulations, and making security decisions that align with business objectives.

Simple Definition

Domain 1 answers one question:

"Why should we protect the organization?"

It teaches organizations to protect their most valuable assets based on risk rather than trying to protect everything equally.

Objectives

After studying this domain, you should understand how to:

- Identify business risks
 - Protect organizational assets
 - Develop security policies
 - Apply governance
 - Follow legal and regulatory requirements
 - Build security awareness
 - Make risk-based security decisions
-

Core Concepts

1. CIA Triad

The CIA Triad is the foundation of information security.

Confidentiality

Ensures information is accessible only to authorized users.

Example:

Only HR staff should access employee salary records.

Integrity

Ensures information remains accurate and is not modified without authorization.

Example:

A student's grades should not be changed by unauthorized users.

Availability

Ensures systems and information remain available when needed.

Example:

Hospital systems must remain operational during emergencies.

What is Risk?

Risk is the possibility that a threat exploits a vulnerability and causes damage to an asset.

Risk Relationship

Asset



Threat



Vulnerability



Risk

Example

Asset:

Customer Database

Threat:

Hacker

Vulnerability:

Weak Password

Risk:

Customer data theft

Risk Formula

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

Higher likelihood and greater impact result in higher risk.

Risk Response Strategies

Organizations generally choose one of four responses.

1. Mitigate

Reduce the risk.

Example: Enable Multi-Factor Authentication (MFA).

2. Accept

Accept the risk when the cost of mitigation is greater than the potential loss.

3. Transfer

Transfer financial responsibility to another party.

Example: Purchase cyber insurance.

4. Avoid

Eliminate the activity causing the risk.

Example: Stop storing unnecessary sensitive data.

Governance

Governance defines:

- Roles
- Responsibilities
- Accountability
- Security strategy
- Decision-making authority

Good governance ensures security supports business objectives.

Security Policies

Policies define what employees are allowed or not allowed to do.

Examples:

- Password Policy
 - Acceptable Use Policy
 - Remote Access Policy
 - Email Security Policy
 - Incident Response Policy
-

Compliance

Organizations must comply with applicable laws, regulations, and industry standards.

Examples:

- GDPR
- HIPAA
- PCI DSS

Important:

Compliance does not automatically mean the organization is secure.

Ethics

Security professionals must follow ethical and legal standards when protecting systems and data.

Domain 1 Summary

Focus Areas:

- Risk Management
 - Governance
 - Policies
 - Compliance
 - Ethics
 - CIA Triad
 - Business Security Decisions
-

Domain 2: Asset Security

Definition

Asset Security focuses on identifying, classifying, handling, storing, protecting, sharing, retaining, and securely disposing of organizational assets.

Simple Definition

Domain 2 answers one question:

"What are we protecting?"

What is an Asset?

An asset is anything valuable to an organization.

Examples include:

- Data
 - Computers
 - Servers
 - Software
 - Cloud Resources
 - Backups
 - Intellectual Property
 - Documents
-

Why Asset Security Matters

Not every asset has the same value.

For example:

- Public Website
- Employee Records
- Customer Credit Card Data
- Source Code

Each asset requires a different level of protection.

Information Classification

Organizations classify information according to its sensitivity.

Example classification:

Public



Internal



Confidential



Restricted

Public

Information available to everyone.

Internal

Information intended only for employees.

Confidential

Sensitive information available only to authorized personnel.

Restricted

Highly sensitive information requiring the strongest protection.

Data Lifecycle

Information must be protected throughout its entire lifecycle.

Create



Store



Use



Share



Archive



Destroy

Three States of Data

1. Data at Rest

Stored data.

Examples:

- Hard Drives
- Databases
- USB Drives

Protection:

- Encryption
- Access Controls

2. Data in Transit

Data moving between systems.

Examples:

- HTTPS
- VPN
- Email

Protection:

- TLS
- VPN Encryption

3. Data in Use

Data currently being processed.

Examples:

- Editing a document
- Running a database query

Protection:

- Access Controls
 - Application Security
-

Data Ownership

Different people have different responsibilities.

Data Owner

Responsible for:

- Data Classification
 - Access Approval
 - Retention Decisions
-

System Owner

Responsible for the systems containing the data.

Data Custodian

Responsible for:

- Storage

- Backups
 - Maintenance
-

User

Authorized individual who accesses and uses the data.

Data Retention

Organizations decide how long information should be kept.

Examples:

- Financial Records: 7 Years
- Temporary Logs: 30 Days

Old information should be securely removed when no longer required.

Secure Disposal

Deleting a file is not enough.

Secure disposal methods include:

- Secure Erase
 - Disk Wiping
 - Physical Destruction
 - Shredding
 - Cryptographic Erasure
-

Domain 2 Summary

Focus Areas:

- Asset Identification
 - Data Classification
 - Data Lifecycle
 - Data States
 - Data Ownership
 - Data Retention
 - Secure Disposal
-

Domain 3: Security Architecture and Engineering

Definition

Security Architecture and Engineering focuses on designing, building, implementing, and maintaining secure systems that protect organizational assets while ensuring the **CIA Triad (Confidentiality, Integrity, and Availability)**.

Simple Definition

Domain 3 answers one question:

"How should we securely design and build systems?"

After identifying **what** to protect (Domain 2), this domain focuses on **how** to protect it through secure architecture and engineering.

Objectives

After studying this domain, you should understand how to:

- Design secure systems
- Build secure architectures
- Apply security design principles
- Implement cryptography

- Secure hardware and software
 - Protect physical infrastructure
 - Build resilient systems
-

Core Concepts

1. Security Architecture

Security Architecture is the blueprint of an organization's security infrastructure.

Examples:

- Firewalls
 - Network Segmentation
 - Authentication Systems
 - VPN
 - Cloud Security Architecture
 - Secure Database Design
-

2. Security Engineering

Security Engineering is the practical implementation of secure designs.

Examples:

- Secure Operating Systems
- Secure APIs
- Secure Databases
- Secure Cloud Infrastructure
- Secure Applications

Architecture = Planning

Engineering = Building

3. Secure Design Principles

Least Privilege

Users receive only the permissions necessary to perform their job.

Example:

An HR employee should not have administrator privileges.

Defense in Depth

Use multiple layers of security instead of relying on a single control.

Example:

Firewall

↓

Antivirus

↓

Multi-Factor Authentication (MFA)

↓

Endpoint Detection and Response (EDR)

↓

SIEM Monitoring

Separation of Duties

Critical tasks are divided among different people.

Example:

One employee creates a payment request.

Another employee approves it.

Fail Secure

If a system fails, it should remain secure rather than granting unauthorized access.

4. Cryptography

Cryptography protects information using mathematical algorithms.

Examples:

- AES
- RSA
- ECC
- Hashing
- Digital Signatures
- Public Key Infrastructure (PKI)

Used to protect:

- Data at Rest
 - Data in Transit
-

5. Physical Security

Physical security protects facilities and hardware.

Examples:

- CCTV
- Security Guards

- Smart Cards
 - Biometrics
 - Mantraps
 - UPS
 - Fire Suppression Systems
-

6. System Resilience

Systems should continue operating during failures or disasters.

Examples:

- RAID
 - Backups
 - High Availability
 - Redundant Power Supplies
 - Disaster Recovery Sites
-

Real-World Example

When designing a banking application, Domain 3 considers:

- Should passwords be hashed?
- Should communication use HTTPS?
- Should the database be encrypted?
- Should JWT tokens expire?
- Should RBAC be implemented?
- Should audit logs be protected?

These are architecture and engineering decisions.

Domain 3 Summary

Focus Areas:

- Security Architecture
- Security Engineering
- Secure Design Principles
- Cryptography
- Physical Security
- System Resilience

Domain 4: Communication and Network Security

Definition

Communication and Network Security focuses on protecting data while it travels across networks and ensuring secure communication between devices, users, and systems.

Simple Definition

Domain 4 answers one question:

"How do systems communicate securely?"

Objectives

After studying this domain, you should understand how to:

- Secure network infrastructure
- Protect network communication
- Secure communication protocols
- Monitor network traffic

- Prevent network attacks
-

Core Concepts

1. Network Architecture

Understanding secure network design.

Components include:

- Routers
 - Switches
 - Firewalls
 - VPN Gateways
 - Load Balancers
 - IDS/IPS
-

2. Network Models

OSI Model

1. Physical
 2. Data Link
 3. Network
 4. Transport
 5. Session
 6. Presentation
 7. Application
-

TCP/IP Model

1. Network Access
2. Internet
3. Transport
4. Application

Understanding these models helps identify where attacks occur and where security controls should be applied.

3. Secure Communication Protocols

Examples:

HTTP → HTTPS

FTP → SFTP

Telnet → SSH

SMTP → SMTPS

DNS → DNSSEC

Encrypted protocols should always be preferred.

4. Firewalls

Firewalls monitor and filter incoming and outgoing network traffic based on predefined security rules.

Example:

Allow:

- HTTPS (443)
- SSH (22)

Block:

- Unauthorized Ports

- Suspicious Connections
-

5. Virtual Private Network (VPN)

VPN creates an encrypted tunnel for secure communication.

Uses:

- Remote Employees
 - Site-to-Site Connections
 - Secure Internet Access
-

6. IDS and IPS

IDS (Intrusion Detection System)

Detects suspicious network activity and generates alerts.

IPS (Intrusion Prevention System)

Detects and automatically blocks malicious traffic.

7. Network Segmentation

Separate networks into smaller secure sections.

Example:

Guest Wi-Fi

↓

Employee Network

↓

Server Network



Database Network

This reduces lateral movement during attacks.

8. Wireless Network Security

Best practices include:

- WPA3
 - Strong Passwords
 - 802.1X Authentication
 - Disable insecure wireless protocols
-

9. Network Monitoring

Continuously monitor network activity using:

- SIEM
- Wireshark
- Zeek
- Suricata
- Splunk
- Microsoft Sentinel

Monitoring helps detect attacks early.

Real-World Example

A user visits:

<https://bank.com>

Domain 4 ensures:

- HTTPS/TLS encrypts communication.
 - Firewalls filter malicious traffic.
 - IDS/IPS detect attacks.
 - Network logs are monitored.
 - Secure DNS resolves the domain.
-

Domain 4 Summary

Focus Areas:

- Network Architecture
 - Secure Communication
 - OSI & TCP/IP Models
 - Secure Protocols
 - Firewalls
 - VPN
 - IDS/IPS
 - Network Segmentation
 - Wireless Security
 - Network Monitoring
-

Domain 5: Identity and Access Management (IAM)

Definition

Identity and Access Management (IAM) focuses on ensuring that **the right person has the right access to the right resources at the right time**, and only for as long as necessary.

Simple Definition

Domain 5 answers one question:

"Who should have access to our systems and data?"

After building secure systems (Domain 3) and securing communication (Domain 4), organizations must control **who is allowed to use those systems**.

Objectives

After studying this domain, you should understand how to:

- Identify users
 - Authenticate users
 - Authorize access
 - Manage user identities
 - Apply access control models
 - Implement Least Privilege
 - Manage the user lifecycle
-

Core Concepts

1. Identification

A user claims an identity.

Example:

Username:

kashif.mashi

2. Authentication

The user proves their identity.

Examples:

- Password
 - PIN
 - Smart Card
 - Fingerprint
 - Face Recognition
 - OTP
 - Multi-Factor Authentication (MFA)
-

3. Authorization

After successful authentication, the system determines what the user is allowed to do.

Example:

A Student can:

- View grades

Cannot:

- Edit grades
-

4. Accounting (Auditing)

Records user activity.

Examples:

- Login time
- Logout time
- Files accessed
- Commands executed

These logs help during investigations and incident response.

AAA Model

Identification



Authentication



Authorization



Accounting

Access Control Models

DAC (Discretionary Access Control)

The owner decides who gets access.

Example:

Google Drive file sharing.

MAC (Mandatory Access Control)

Access is controlled by security classifications.

Commonly used in:

- Military

- Government
-

RBAC (Role-Based Access Control)

Access is based on job roles.

Example:

HR

Manager

SOC Analyst

Administrator

ABAC (Attribute-Based Access Control)

Access depends on multiple attributes.

Examples:

- User
 - Device
 - Location
 - Time
 - Department
-

Least Privilege

Users receive only the permissions necessary to perform their jobs.

Example:

A receptionist should not have database administrator privileges.

Zero Trust

Core Principle:

"Never Trust, Always Verify."

Every access request must be authenticated and authorized continuously.

Identity Lifecycle

Create User



Grant Access



Modify Access



Disable Account



Delete Account

Access should be reviewed whenever a user's role changes or they leave the organization.

Multi-Factor Authentication (MFA)

Authentication uses two or more different factors.

Something you:

Know → Password

Have → Mobile Phone

Are → Fingerprint

Real-World Example

A company employee logs into Microsoft 365.

The system:

- Identifies the username.
 - Authenticates using a password and MFA.
 - Authorizes access based on the employee's role.
 - Records login activity in audit logs.
-

Domain 5 Summary

Focus Areas:

- Identity Management
- Authentication
- Authorization
- Accounting
- Access Control Models
- MFA
- Least Privilege

- Zero Trust

Domain 6: Security Assessment and Testing

Definition

Security Assessment and Testing focuses on evaluating whether an organization's security controls are working effectively.

Simple Definition

Domain 6 answers one question:

"How do we know our security actually works?"

Building security is not enough.

Organizations must continuously test, verify, and improve their security.

Objectives

After studying this domain, you should understand how to:

- Assess security controls
- Perform vulnerability assessments
- Conduct penetration testing
- Review logs
- Audit systems
- Measure security effectiveness

Core Concepts

1. Security Assessments

Evaluate the effectiveness of security controls.

Examples:

- Configuration Reviews
 - Security Audits
 - Compliance Reviews
-

2. Vulnerability Assessment

Identifies weaknesses in systems.

Examples:

- Missing Patches
- Weak Passwords
- Open Ports
- Misconfigurations

Tools:

- Nessus
 - OpenVAS
 - Qualys
-

3. Penetration Testing

Attempts to exploit vulnerabilities to determine whether they are actually exploitable.

Purpose:

Simulate a real attacker.

Tools:

- Metasploit
- Burp Suite
- Nmap

- Kali Linux

Vulnerability Assessment vs Penetration Testing

Vulnerability Assessment	Penetration Testing
Finds weaknesses	Attempts to exploit weaknesses
Broad coverage	Deep testing
Lower risk	Higher risk (authorized only)
Produces a list of issues	Demonstrates real-world impact

4. Security Audits

Verify compliance with:

- Company Policies
- ISO 27001
- PCI DSS
- Government Regulations

5. Log Review

Security teams review:

- Authentication Logs
- Firewall Logs
- Server Logs
- Application Logs
- SIEM Alerts

Purpose:

Detect suspicious activity.

6. Security Metrics

Organizations measure security performance using metrics such as:

- Number of vulnerabilities
 - Patch Compliance
 - Incident Response Time
 - Mean Time to Detect (MTTD)
 - Mean Time to Respond (MTTR)
-

7. Continuous Testing

Security is not a one-time activity.

Organizations regularly:

- Scan
 - Test
 - Audit
 - Monitor
 - Improve
-

Real-World Example

A company launches a new website.

Before deployment:

- Nessus scans for vulnerabilities.
- Penetration testers attempt to exploit weaknesses.

- Auditors verify compliance.
 - Security teams review logs.
 - Any discovered issues are fixed before production.
-

Domain 6 Summary

Focus Areas:

- Security Assessments
 - Vulnerability Assessments
 - Penetration Testing
 - Audits
 - Log Reviews
 - Security Metrics
 - Continuous Testing
-

Domain 7: Security Operations

Definition

Security Operations focuses on the **day-to-day management, monitoring, detection, response, and recovery** of an organization's security.

Simple Definition

Domain 7 answers one question:

"How do we protect and operate our security every day?"

Even after systems are built, users are authenticated, and security controls are tested, organizations must continuously monitor and defend against attacks.

Objectives

After studying this domain, you should understand how to:

- Monitor security events
 - Detect cyber attacks
 - Respond to security incidents
 - Recover from attacks
 - Manage backups
 - Perform disaster recovery
 - Maintain business continuity
 - Manage operational security
-

Core Concepts

1. Security Monitoring

Continuously monitor systems and networks to identify suspicious activity.

Examples:

- SIEM
 - EDR
 - Firewall Logs
 - Windows Event Logs
 - Linux Logs
-

2. Incident Response (IR)

When an attack occurs, organizations follow an Incident Response process.

Incident Response Lifecycle

Preparation

↓

Detection & Analysis

↓

Containment

↓

Eradication

↓

Recovery

↓

Lessons Learned

3. Logging and Monitoring

Security teams collect logs from:

- Servers
- Firewalls
- Applications
- Databases
- Active Directory
- Cloud Services

Purpose:

- Detect attacks
 - Investigate incidents
 - Support forensic analysis
-

4. Backup and Recovery

Backups help restore data after:

- Ransomware
- Hardware Failure
- Human Error
- Natural Disasters

Types:

- Full Backup
 - Incremental Backup
 - Differential Backup
-

5. Disaster Recovery (DR)

Disaster Recovery restores IT systems after major disruptions.

Examples:

- Secondary Data Centers
 - Cloud Recovery
 - Disaster Recovery Plans
-

6. Business Continuity (BC)

Business Continuity ensures critical business operations continue during disruptions.

Example:

An online bank continues serving customers even if one data center fails.

7. Change Management

Changes to systems should follow an approval process.

Example:

Before updating a firewall rule:

- Review
 - Test
 - Approve
 - Implement
 - Monitor
-

8. Digital Forensics

Digital Forensics investigates cyber incidents by collecting and preserving digital evidence.

Examples:

- Disk Imaging
 - Memory Analysis
 - Log Analysis
 - Timeline Analysis
-

Real-World Example

A ransomware attack is detected.

Security Operations:

- Detects suspicious encryption.
 - Isolates infected systems.
 - Removes malware.
 - Restores data from backups.
 - Investigates the attack.
 - Documents lessons learned.
-

Domain 7 Summary

Focus Areas:

- Security Operations
 - SIEM
 - Incident Response
 - Logging
 - Monitoring
 - Backup
 - Disaster Recovery
 - Business Continuity
 - Digital Forensics
 - Change Management
-

Domain 8: Software Development Security

Definition

Software Development Security focuses on integrating security into the **Software Development Life Cycle (SDLC)** to build secure applications.

Simple Definition

Domain 8 answers one question:

"How do we build secure software?"

Instead of fixing vulnerabilities after deployment, security should be included throughout software development.

Objectives

After studying this domain, you should understand how to:

- Build secure applications
 - Secure the Software Development Life Cycle (SDLC)
 - Prevent software vulnerabilities
 - Secure APIs
 - Secure source code
 - Test application security
-

Core Concepts

1. Secure SDLC

Security should be included in every phase.

Requirements

↓

Design

↓

Development



Testing



Deployment



Maintenance

2. Secure Coding

Developers should write secure code.

Examples:

- Input Validation
 - Parameterized Queries
 - Error Handling
 - Secure Authentication
 - Output Encoding
-

3. Common Vulnerabilities

Examples:

- SQL Injection

- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Buffer Overflow
- Broken Authentication

Reference:

OWASP Top 10

4. Code Review

Developers review source code before deployment.

Purpose:

- Detect bugs
 - Improve quality
 - Find security vulnerabilities
-

5. Application Security Testing

Types include:

- Static Application Security Testing (SAST)
 - Dynamic Application Security Testing (DAST)
 - Interactive Application Security Testing (IAST)
 - Software Composition Analysis (SCA)
-

6. Dependency Management

Modern applications use third-party libraries.

Organizations should:

- Update dependencies
 - Patch vulnerabilities
 - Remove unsupported packages
-

7. DevSecOps

Security becomes part of the CI/CD pipeline.

Developers, Operations, and Security teams work together to automate security throughout development.

Real-World Example

A FastAPI application is developed.

Before deployment:

- Validate all user input.
 - Hash passwords using bcrypt.
 - Use JWT securely.
 - Implement RBAC.
 - Scan dependencies.
 - Run SAST and DAST tools.
 - Fix vulnerabilities.
 - Deploy securely.
-

Domain 8 Summary

Focus Areas:

- Secure SDLC
- Secure Coding

- Application Security
 - Code Review
 - OWASP Top 10
 - SAST
 - DAST
 - DevSecOps
 - Dependency Management
-

One-Line Summary of All 8 Domains

Domain	Main Question
1	Why do we need security?
2	What are we protecting?
3	How do we design and build secure systems?
4	How do systems communicate securely?
5	Who should have access?
6	How do we verify security works?
7	How do we operate, monitor, and respond every day?
8	How do we build secure software?

If you remember these **eight questions**, you'll have a strong conceptual understanding of the entire CISSP Common Body of Knowledge (CBK).
